

Die Vertiefung des Datenhaltungskonzepts: Ein strategischer Leitfaden für moderne IT-Infrastrukturen

Autor: Mevluet Polat

Zusammenfassung

In einer zunehmend digitalisierten und datengetriebenen Wirtschaft stellt das Datenhaltungskonzept das Rückgrat der unternehmerischen Informationssicherheit und IT-Governance dar. Der vorliegende Artikel analysiert die Vertiefung und praktische Anwendung von Datenhaltungskonzepten in modernen IT-Umgebungen. Basierend auf vier zentralen Säulen – der Übertragung auf neue Systeme, der Anwendung auf bestehende Systeme, der strikten Implementierung der 3-2-1-Backup-Regel sowie der integralen Verzahnung mit dem Disaster Recovery – wird aufgezeigt, wie Unternehmen ihre Datenintegrität, Verfügbarkeit und Vertraulichkeit gewährleisten können. Anhand von detaillierten Praxisbeispielen werden die theoretischen Konstrukte greifbar gemacht. Besondere Berücksichtigung findet dabei auch die Perspektive des Schweizer Datenschutzrechts.

1. Einleitung und Relevanz des Themas

Daten sind das wertvollste Gut moderner Unternehmen. Der Verlust, die Korruption oder die unautorisierte Offenlegung von Unternehmensdaten kann existenzbedrohende Ausmasse annehmen. Ein Datenhaltungskonzept (DHK) ist weit mehr als eine blosse technische Spezifikation für Speichermedien; es ist ein ganzheitliches, strategisches Dokument, das den Lebenszyklus von Daten – von der Entstehung bis zur revisionssicheren Löschung – regelt. Es definiert, wie Daten klassifiziert, gespeichert, gesichert und im Notfall wiederhergestellt werden.

In der Praxis zeigt sich jedoch häufig eine Diskrepanz zwischen dem theoretisch definierten Konzept und der gelebten IT-Realität. Historisch gewachsene Infrastrukturen, die rasante Einführung von Cloud-Diensten (Cloud-Computing) und die ständige Bedrohung durch Cyberangriffe (wie Ransomware) zwingen Organisationen dazu, ihre Datenhaltungskonzepte nicht nur iterativ zu überarbeiten, sondern tief in die operativen Prozesse zu integrieren. Dieser Artikel beleuchtet die kritischen Phasen dieser Vertiefung und liefert konkrete Handlungsanweisungen, um die Lücke zwischen Theorie und Praxis zu schliessen.

2. Das Konzept auf neue Systeme übertragen

(Onboarding und Skalierbarkeit)

Die IT-Landschaft eines Unternehmens ist kein statisches Gebilde. Ständig werden neue Applikationen, Software-as-a-Service (SaaS)-Lösungen oder Infrastrukturkomponenten eingeführt. Die grösste Herausforderung besteht darin, dass diese neuen Systeme nicht als isolierte Datensilos entstehen, sondern sich nahtlos in die bestehenden Sicherheits- und Speicherarchitekturen einfügen.

2.1 Theoretische Grundlagen

Die Übertragbarkeit eines bestehenden Datenhaltungskonzepts ist ein Qualitätsmerkmal der IT-Governance. Ein Konzept muss so generisch und flexibel gestaltet sein, dass es auf neuartige Technologien (z. B. Container-Lösungen wie Kubernetes oder serverlose Architekturen) adaptiert werden kann, ohne seine Kernprinzipien zu verlieren.

Beim **Onboarding** neuer Applikationen wird das Datenhaltungskonzept systematisch angewendet. Dies erfordert eine detaillierte **Lückenanalyse** (Gap-Analyse), bei der geprüft wird, ob das bestehende Regelwerk alle Facetten des neuen Systems abdeckt. Die **Standardisierung** von Vorgehensweisen – etwa durch Checklisten oder automatisierte Workflows im IT-Service-Management (ITSM) – reduziert den administrativen Aufwand und minimiert Fehlerquellen. Letztlich ist die **Verantwortung** entscheidend: Projektverantwortliche und Product Owner stehen in der Pflicht, neue Systeme bereits in der Konzeptionsphase (Security by Design) im Datenhaltungskonzept zu erfassen und die darin verarbeiteten Daten zu klassifizieren (z. B. intern, vertraulich, streng vertraulich).

2.2 Praxisbeispiel: Einführung eines cloudbasierten HR-Systems

Ein mittelgrosses Schweizer Industrieunternehmen entscheidet sich, seine veraltete Personalverwaltung durch ein modernes, cloudbasiertes Human Resources (HR) System zu ersetzen.

- **Die Lückenanalyse:** Der Projektleiter stellt bei der Lückenanalyse fest, dass das bisherige Datenhaltungskonzept nur On-Premises-Systeme (lokale Server) abdeckt. Cloud-Systeme wurden bisher nicht umfassend reguliert.
- **Die Adaption:** Das Konzept muss erweitert werden, um Vorgaben für SaaS-Anbieter zu integrieren. Es wird definiert, dass Personaldaten der höchsten Vertraulichkeitsstufe unterliegen.
- **Die Standardisierung und Verantwortung:** Der Projektverantwortliche wendet die standardisierte Onboarding-Checkliste an. Er stellt sicher, dass der SaaS-Anbieter garantieren kann, dass die Backups der HR-Daten gemäss den internen Richtlinien erstellt werden. Zudem muss vertraglich zugesichert werden, dass die Daten den Schweizer oder europäischen Raum nicht verlassen, um Compliance-Vorgaben zu genügen. Erst nachdem das neue System vollständig im Inventar des Datenhaltungskonzepts klassifiziert

und dokumentiert ist, darf der produktive Betrieb starten.

3. Das Konzept auf bestehende Systeme anwenden (Bereinigung und Optimierung)

Während neue Systeme relativ einfach nach aktuellen Standards eingeführt werden können (Greenfield-Ansatz), stellen bestehende, historisch gewachsene Systeme (Legacy-IT) eine ungleich grössere Herausforderung dar. Diese Systeme wurden oft zu einer Zeit implementiert, als das aktuelle Datenhaltungskonzept noch gar nicht existierte.

3.1 Theoretische Grundlagen

Die Anwendung des Konzepts auf Legacy-Systeme beginnt zwingend mit einer umfassenden **Bestandsanalyse**. Hierbei wird ein vollständiges Inventar aller Applikationen, Datenbanken und Dateiserver erstellt und abgeglichen. Vielfach stösst man dabei auf sogenannte "Schatten-IT" – Systeme, die von Fachabteilungen an der zentralen IT vorbei betrieben werden.

Darauf folgt die **Aktualisierung** der Metadaten. Veraltete Klassifizierungen müssen bereinigt werden. Ein zentraler Punkt ist der **Technologievergleich**: Entsprechen die Backup-Technologien eines 15 Jahre alten ERP-Systems noch den Vorgaben des aktuellen Konzepts? Oftmals ist dies nicht der Fall.

Aus den Erkenntnissen der Analyse wird ein verbindlicher **Massnahmenplan** abgeleitet. Da Ressourcen in der IT stets limitiert sind, ist eine strikte **Priorisierung** unabdingbar. Systeme mit einer hohen Business-Kritikalität (geschäftskritische Systeme) oder solche, die besonders schützenswerte Personendaten verarbeiten, müssen bei der Behebung von Abweichungen bevorzugt behandelt werden.

3.2 Praxisbeispiel: Das veraltete Produktionssteuerungssystem

Ein traditionsreiches Schweizer Pharmaunternehmen betreibt ein System zur Produktionssteuerung, das seit zehn Jahren im Einsatz ist.

- **Bestandsanalyse und Technologievergleich:** Im Rahmen eines IT-Audits wird dieses System auf Basis des neuen Datenhaltungskonzepts geprüft. Die Analyse offenbart eine kritische Abweichung: Das System sichert seine Datenbank lediglich einmal wöchentlich auf lokale Magnetbänder (Tape-Backup), welche zudem im selben Brandabschnitt aufbewahrt werden. Das neue Konzept verlangt für geschäftskritische Systeme jedoch stündliche inkrementelle Backups und eine Auslagerung in ein externes Rechenzentrum.
- **Priorisierung und Massnahmenplan:** Da ein Ausfall dieses Systems die gesamte Medikamentenproduktion stoppen würde (hohe Kritikalität), wird der Vorfall mit der höchsten Priorität (Priorität 1) eingestuft.
- **Aktualisierung:** Der Massnahmenplan sieht vor, dass innerhalb von vier Wochen eine

moderne Backup-Software-Agenten-Lösung installiert wird, die stündliche Snapshots auf ein redundantes Disk-Storage-System erstellt. Die alten Bandlaufwerke werden ausgemustert und das System wird im zentralen IT-Register korrekt mit seiner hohen Kritikalität und den neuen Backup-Vorgaben vermerkt.

4. Die 3-2-1 Regel im Datenhaltungskonzept verankern

Die Methodik, wie Daten gesichert werden, bildet den technischen Kern eines jeden Datenhaltungskonzepts. Die sogenannte 3-2-1-Backup-Regel hat sich in der IT-Sicherheit als absoluter Best-Practice-Standard etabliert, um Datenverlust durch Hardwaredefekte, Elementarschäden oder Cyberkriminalität zu verhindern.

4.1 Theoretische Grundlagen

Die 3-2-1 Regel besagt, dass mindestens **drei (3)** Kopien der Daten existieren müssen (die produktiven Originaldaten plus zwei Backups). Diese Backups müssen auf mindestens **zwei (2)** unterschiedlichen Speichermedien (z. B. Disk und Tape, oder lokales SAN und Cloud-Storage) abgelegt werden. Eine **(1)** dieser Kopien muss physisch getrennt (Offsite) aufbewahrt werden, um bei lokalen Katastrophen wie einem Brand oder einer Überschwemmung geschützt zu sein.

Das Datenhaltungskonzept fordert die explizite **Verankerung** dieser Regel als absoluten Mindeststandard. Gleichzeitig muss das Konzept pragmatisch sein: Es bedarf klar definierter **Ausnahmen**, falls die Regel aus technischen (z. B. bei extremen Datenmengen im Petabyte-Bereich, wo eine Dreifachkopie wirtschaftlich untragbar ist) oder rechtlichen Gründen nicht anwendbar ist.

Ein entscheidender Faktor ist die **Datenschutzkonformität**. Besonders in der Schweiz müssen Offsite-Kopien (insbesondere beim Cloud-Backup) den strengen Auflagen des revidierten Datenschutzgesetzes (revDSG) entsprechen. Das Konzept muss klare **Technologievorgaben** (z. B. Verschlüsselungsalgorithmen wie AES-256, Immutability/Unveränderbarkeit der Backups gegen Ransomware) machen und einen regelmässigen **Umsetzungsnachweis** (Monitoring und Auditing) einfordern.

4.2 Praxisbeispiel: Patientendaten in einem Schweizer Spital

Ein Kantonsspital muss enorme Mengen an Patientendaten, Röntgenbildern (PACS) und elektronischen Patientendossiers (EPD) sicher speichern.

- **Verankerung und Technologievorgaben:** Das Spital verankert die 3-2-1 Regel in seinem Datenhaltungskonzept. Kopie 1 sind die produktiven Server (All-Flash-Storage). Kopie 2 liegt auf einem sekundären NAS-System in einem anderen Gebäudetrakt (Medium 1: Disk). Kopie 3 wird täglich auf ein Immutable-Storage-System in der Cloud eines zertifizierten Schweizer Providers repliziert (Medium 2: Object Storage in der Cloud, Offsite). Das "Immutable" (unveränderbare) Format ist eine technologische Vorgabe des Konzepts, um

zu verhindern, dass Ransomware die Backups verschlüsseln kann.

- **Datenschutzkonformität:** Das Konzept prüft und protokolliert zwingend, dass der Cloud-Provider seine Rechenzentren ausschliesslich auf Schweizer Boden betreibt und keine fremden Geheimdienste (z. B. durch den US CLOUD Act) Zugriff auf die Gesundheitsdaten haben.
- **Ausnahmen und Umsetzungsnachweis:** Eine Ausnahme wird für die Rohdaten des Gen-Sequenzierungs-Labors definiert. Da hier täglich Terabytes an flüchtigen Daten generiert werden, die im Notfall neu berechnet werden können, reicht hier ein einfaches, lokales Backup (Wirtschaftlichkeitsprüfung). Das IT-Sicherheitsteam muss monatlich einen Bericht an die Klinikleitung übergeben, der die Einhaltung der 3-2-1 Regel für alle klassifizierten Systeme nachweist.

5. Verzahnung von Datenhaltungskonzept und Disaster Recovery (DR)

Ein Backup ist wertlos, wenn es im Krisenfall nicht rechtzeitig und konsistent wiederhergestellt werden kann. Daher ist die isolierte Betrachtung der Datenhaltung unzureichend. Das Datenhaltungskonzept muss integraler Bestandteil der Business Continuity Management (BCM) Strategie und insbesondere des Disaster Recovery (DR) Plans sein.

5.1 Theoretische Grundlagen

Die **Verzahnung** beider Disziplinen stellt sicher, dass theoretisch gesicherte Daten praktisch nutzbar bleiben. Das Datenhaltungskonzept muss zwingende **DR-Vorgaben** enthalten, die festlegen, für welche Systemklassen eine vollumfängliche, schnelle Notfallwiederherstellung konzipiert werden muss.

Ein zentraler KPI (Key Performance Indicator) ist das **RTO (Recovery Time Objective)** – die maximal tolerierbare Ausfallzeit eines Systems, bis es wieder produktiv zur Verfügung stehen muss. Ein zweiter, oft korrelierender Wert ist das **RPO (Recovery Point Objective)**, welches den maximal tolerierbaren Datenverlust in der Zeit misst. Die im Datenhaltungskonzept definierten RTO- und RPO-Werte fliessen direkt in die DR-Planung ein und diktieren die Infrastrukturauswahl (z. B. asynchrone Replikation vs. synchroner Spiegel).

Um die Funktionalität zu garantieren, müssen **Testintegrationen** vorgeschrieben sein. DR-Tests (von Tabletop-Übungen bis hin zu vollständigen Failover-Tests) sind keine Kür, sondern eine Pflicht. Schliesslich muss eine klare **Gesamtverantwortung** (oft beim Chief Information Security Officer oder dem IT Service Continuity Manager) definiert werden, um sicherzustellen, dass bei Veränderungen der Infrastruktur sowohl das DHK als auch der DR-Plan synchronisiert aktualisiert werden.

5.2 Praxisbeispiel: Cyberangriff auf ein Logistikunternehmen

Ein international agierendes Schweizer Logistikunternehmen ist auf die lückenlose Verfügbarkeit seines Flottenmanagement- und Routenplanungssystems angewiesen.

- **RTO im Konzept und DR-Vorgaben:** Das Datenhaltungskonzept klassifiziert dieses System als "unternehmenskritisch". Es definiert ein RTO von maximal 4 Stunden und ein RPO von 15 Minuten. Diese Vorgaben aus dem DHK zwingen die DR-Verantwortlichen, eine Architektur zu wählen, bei der die Daten alle 15 Minuten repliziert werden und im Notfall per Knopfdruck in einem Ausweichrechenzentrum hochgefahren werden können (Hot-Standby).
- **Der Ernstfall (Verzahnung):** An einem Freitagmorgen wird das primäre Rechenzentrum des Unternehmens Opfer einer ausgeklügelten Ransomware-Attacke. Alle operativen Server werden verschlüsselt. Da das Datenhaltungskonzept und der DR-Plan perfekt aufeinander abgestimmt sind, greift sofort der Notfallplan.
- **Testintegration als Lebensretter:** Da im Datenhaltungskonzept jährliche, verbindliche DR-Tests verankert sind, weiss das IT-Team genau, was zu tun ist. Sie isolieren das infizierte Netzwerk, greifen auf die unangetasteten Offsite-Backups (gemäss 3-2-1 Regel) zurück und starten die Systeme im Ausweichrechenzentrum. Dank der strikten Vorgaben und regelmässigen Übungen sind die Systeme nach 3,5 Stunden wieder online – das geforderte RTO von 4 Stunden wurde eingehalten, die Lastwagen können weiter disponiert werden, der wirtschaftliche Totalschaden wurde abgewendet.

6. Zukunftsbetrachtung und Weiterentwicklung

Die im Datenhaltungskonzept festgeschriebenen Prinzipien sind nicht in Stein gemeisselt. Mit dem Aufkommen von künstlicher Intelligenz (KI) im IT-Betrieb (AIOps) bieten sich neue Möglichkeiten der Automatisierung. Zukünftig werden Systeme in der Lage sein, sich selbstständig zu klassifizieren und Backup-Intervalle dynamisch anhand des Nutzerverhaltens anzupassen. Dennoch bleibt die intellektuelle Vorarbeit, wie sie von Mevluet Polat skizziert wurde, unerlässlich. Konzepte wie "Zero Trust" (Vertraue niemandem, überprüfe alles) müssen zunehmend auch auf die Datenhaltung angewendet werden, indem beispielsweise Administratoren-Zugriffe auf Backup-Daten durch das Vier-Augen-Prinzip (Multi-Party-Authorization) geschützt werden, um Insider-Bedrohungen vorzubeugen.

7. Fazit

Ein Datenhaltungskonzept entfaltet seine schützende Wirkung erst dann, wenn es den Weg vom geduldigen Papier in die pulsierende IT-Realität eines Unternehmens findet. Die Vertiefung dieses Konzepts erfordert eine systematische Herangehensweise an vier Fronten: Die konsequente Durchsetzung von Richtlinien beim Onboarding neuer Systeme verhindert das Entstehen zukünftiger Sicherheitslücken. Die akribische Bestandsanalyse und Bereinigung bestehender Legacy-Systeme tilgt historische Altlasten und reduziert die Angriffsfläche massiv.

Die kompromisslose Verankerung der 3-2-1-Backup-Regel, unter besonderer Berücksichtigung lokaler Datenschutzgesetze, bildet das unerschütterliche Fundament der Datenintegrität. Doch selbst die besten Backups sind nutzlos ohne eine nahtlose Verzahnung mit dem Disaster Recovery Plan, die durch regelmässige Tests und klare RTO-Vorgaben die Handlungsfähigkeit im Krisenfall sichert. Nur wenn Führungskräfte die Verantwortung für diese Massnahmen übernehmen und sie in der Unternehmenskultur verankern, wird das Datenhaltungskonzept von einer reinen Compliance-Übung zu einem echten strategischen Wettbewerbsvorteil, der das Überleben der Organisation im digitalen Zeitalter sichert.

Quellenverzeichnis

1. **Polat, M.** (ohne Jahr). *Präsentationsfolien: Datenhaltungskonzept – Vertiefung*. (Folie 10: Konzept auf neue Systeme übertragen; Folie 11: Konzept auf bestehende Systeme anwenden; Folie 12: Konzept und 3-2-1 Regel; Folie 13: Konzept und Disaster Recovery). Internes Dokument.
2. **Bundesversammlung der Schweizerischen Eidgenossenschaft.** (2020). *Bundesgesetz über den Datenschutz (Datenschutzgesetz, DSG)*. Stand am 1. September 2023. Systematische Sammlung des Bundesrechts (SR 235.1).
3. **Bundesamt für wirtschaftliche Landesversorgung (BWL) / Nationale Stelle für Cybersicherheit (NCSC).** (2023). *Empfehlungen zum Schutz vor Ransomware und zur Sicherstellung der Business Continuity*. Bern.
4. **BSI – Bundesamt für Sicherheit in der Informationstechnik.** (2022). *IT-Grundschutz-Kompendium: Baustein CON.3 Datensicherungskonzept*. Bonn. (Herangezogen für Best-Practice-Methodiken im deutschsprachigen Raum).
5. **ITIL® 4 Foundation.** (2019). *IT Service Management Practices*. AXELOS Limited. (Herangezogen für die Definitionen von IT-Onboarding, ITSM und Lifecycle-Management).
6. **ISO/IEC 27001:2022.** (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. International Organization for Standardization. (Herangezogen für die Konzepte von Disaster Recovery, RTO und RPO).